

甘肃国邦信息科技有限公司

信息安全管理制

SXXDC-ITSS-15-08

拟制人：_____胡葛鹏宇_____

审核人：_____兰伟东_____

批准人：_____赵 鑫_____

修改记录

[illegible]

目录

1. 目的	1
2. 适用范围	1
3. 术语及定义	1
4. 职责	1
4.1 运维部经理	1
4.2 项目经理	1
4.3 运维工程师	1
5. 内容	2
5.1 信息安全方针	2
5.2 信息安全分级	2
5.3 信息安全管理流程	4
5.3.1 信息安全管理流程图	4
5.3.2 信息安全管理流程说明	4
6. 度量与验证	6
7. 相关记录	7

1. 目的

规定了运维服务商在提供服务与作业活动中,对客户关键应用所关联的资产进行风险等级评估并采取相应的控制措施的方法。

2. 适用范围

本文档适用于甘肃国邦信息科技有限公司。

3. 术语及定义

术语	定义
机密性	指保护信息免受未经授权的访问和使用。
完整性	指信息的准确性、完全性和及时性。
可用性	是信息在任何约定的时间内都可以被访问。这取决于由信息处理系统所提供的持续性。

4. 职责

4.1 运维部经理

- 指导、处理与安全相关的问题和事件;
- 协助项目经理做好信息安全监督、管理工作。

4.2 项目经理

- 负责制定维护项目安全范围和规范;
- 负责安排项目中的信息安全风险评估;
- 确保满足 SLA 中指定的安全需求;
- 负责该项目安全管理的严格实施和持续监控;
- 在日常服务工作中,严格执行相应信息安全管理规范和要求。

4.3 运维工程师

- 负责确定客户和业务对运维服务信息安全的详细需求;
- 负责记录系统运行过程中的安全事件记录;

- 识别信息安全管理过程中存在的问题并提出改进措施；
- 在日常服务工作中，严格执行相应信息安全管理规范和要求。

5. 内容

5.1 信息安全方针

运维服务商从流程、技术、人员层面保障信息安全，不让服务活动造成信息价值的损失。本手册制定了信息安全方针：“全面管理，积极预防，持续改进”，以指导信息安全管理。

在规划和实施信息安全管理时应：

- 传达信息安全方针及遵守该方针的重要性；
- 建立信息安全管理目标；
- 管理信息安全风险所采取的方法和风险接受准则；
- 按计划在规定的時間间隔实施信息安全风险评估；
- 公司每年对信息安全进行一次内审；
- 识别评审过程中存在的问题，并提出改进措施。

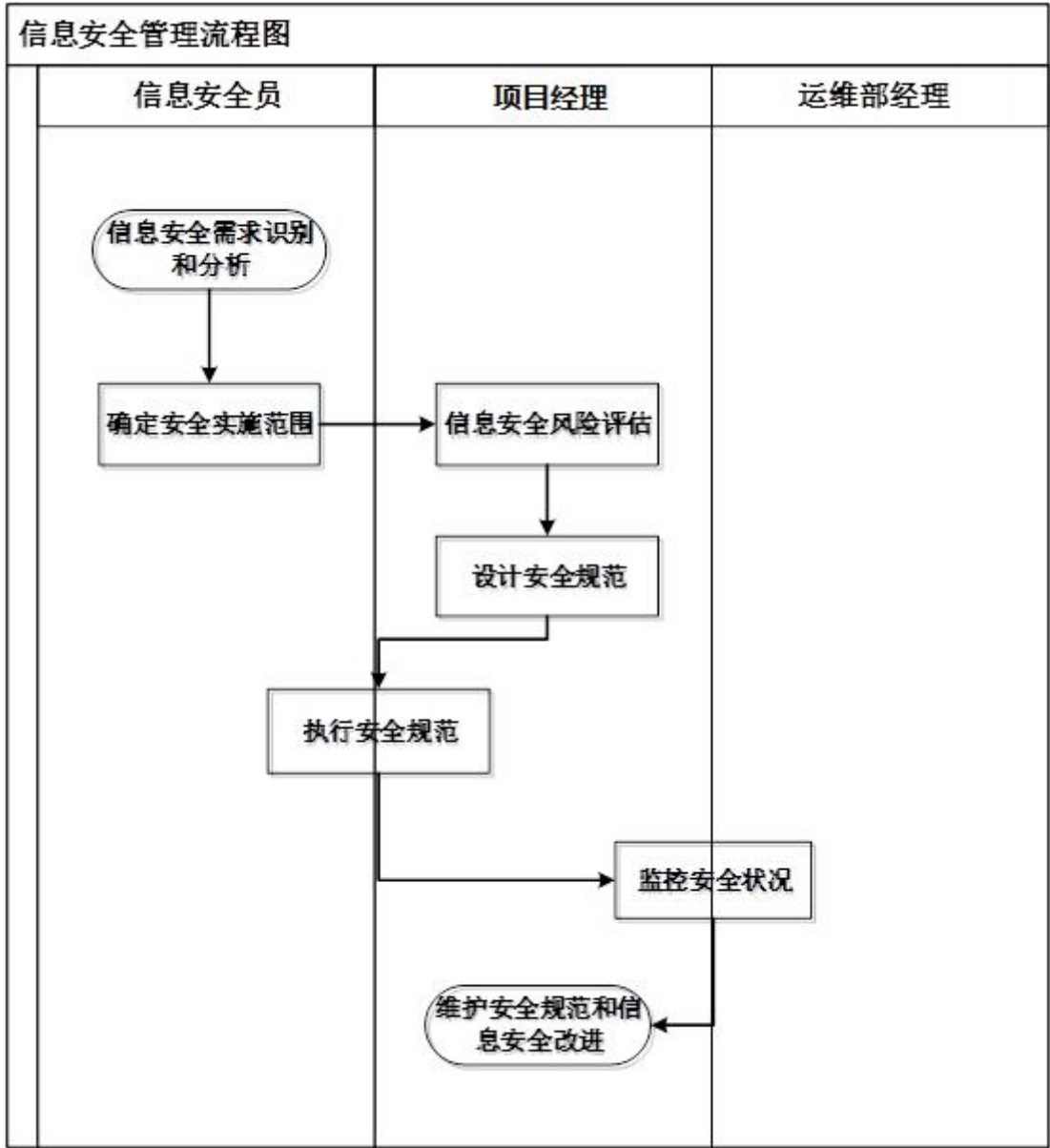
5.2 信息安全分级

信息安全等级	C - 机密性	I - 完整性	A - 可用性
4 (非常高)	包含客户最重要的秘密，关系未来发展的前途命运，对客户根本利益有着决定性影响，如果泄漏会造成灾难性的损害。	完整性价值非常关键，未经授权的修改或破坏会对客户造成重大的或无法接受的影响，对业务冲击重大，并可能造成严重的业务中断，难以弥补。	可用性价值非常高，合法使用者对信息及信息系统的可用度达到年度99.9%以上。
3(高)	包含客户的重要秘密，其泄露会使客户	完整性价值较高，未经授权的修改或破坏会对客户	可用性价值较高，合法使用者对信息

	的安全和利益遭受严重损害。	造成重大影响，对业务冲击严重，比较难以弥补。	及信息系统的可用度达到每天 90%以上。
2(中)	包含客户的一般性秘密，其泄露会使客户的安全和利益受到损害。	完整性价值中等，未经授权的修改或破坏会对客户造成影响，对业务冲击明显，但可以弥补。	可用性价值中等，合法使用者对信息及信息系统的可用度在正常工作时间达到 70%以上。
1(低)	包含仅能在客户内部或在客户某一部门内部公开的信息，向外扩散有可能对客户的利益造成损害。	完整性价值较低，未经授权的修改或破坏会对客户造成轻微影响，可以忍受，对业务冲击轻微，容易弥补。	可用性价值较低，合法使用者对信息及信息系统的可用度在正常工作时间达到 25%以上。

5.3 信息安全管理流程

5.3.1 信息安全管理流程图



5.3.2 信息安全管理流程说明

1) 信息安全需求识别和分析

识别客户对运维信息安全的需求和目标，进行信息安全需求分析。需求识别包括人员、数据等安全风险的需求。信息安全需求的来源主要包括：

- 服务合同或 SLA 相关条款中约定；

-
- 法律法规的要求；
 - 客户业务特点或所在行业业务特性所确定的安全要求；
 - 公司内部的安全要求。

2) 确定安全实施范围

根据安全需求确定安全实施范围。安全实施范围包括相应安全等级的机房环境、设备、系统、数据、人员等。

3) 信息安全风险评估

由涉及部门及客户负责人根据资产识别情况制定风险评估方法,通过识别信息资产、风险等级评估认知本公司的安全风险,在考虑控制成本与风险平衡的前提下选择合适控制目标和控制方式将安全风险控制在可接受的水平,并提交《信息安全风险评估报告》。

采用定量风险分析方法对风险的发生概率和风险的影响进行分析,计算出风险值 = 风险概率*风险影响。确定风险阈值(风险阈值是风险控制点,对于达到该阈值的风险,需要制订风险缓解措施。风险阈值定义为 1.5,如果阈值达到 1.5,需要制定缓解措施。),以便确定风险的可接受度或不可接受度,再根据风险值确定风险相对优先顺序。

4) 设计安全规范

根据《信息安全风险评估报告》,安全工程师制定和编写《信息安全管理规范》。并根据《信息安全管理规范》制定信息安全策略、针对个人的保密协议、岗位职责说明等。

5) 实施安全规范

在设计好安全规范后,在日常服务工作中须按照安全规范来实施安全管理。

6) 监控安全状况

对安全规范实施进行监控，根据合同约定在服务报告中体现，制定《信息安全事件统计表》。

7) 维护安全规范和信息安全改进

项目经理根据系统运行及客户服务的风险变化；及由于基础机构、组织和业务流程方面的变化导致的风险变化，必要时对《信息安全管理规范》进行安全维护修改。安全维护包括服务级别协议中安全部分的维护以及详细的安全规范的维护。维护需要根据评估子系统流程的结果以及对风险变化的评估结果进行。

信息安全实施过程中，针对存在的问题进行相应的改进计划和改进措施。

8) 信息安全报告

对信息安全管理实施状况及日常发生的安全事件等需编写安全报告。

报告可以提供有关已实现安全绩效方面的信息，并可以了解有关的安全问题。

正确地了解有关努力（如安全措施的实施）所取得的效率以及实际被采用的安全措施。

信息安全事件：所有引起信息的机密性（预防数据欺骗及组织敏感信息泄漏），完整性（防止数据被篡改）和可用性缺失（核心业务的连续性）的事件都是信息安全事件。（例如病毒引起的故障，由于密码失窃引发的事件等等）

项目经理应定期分析和汇总信息安全事件，生成《信息安全事件统计表》，以报告当前的信息安全现状。

6. 度量与验证

重大信息安全事故次数 0 次/年

重大信息安全事故次数指的是：泄密及信息安全数据丢失等重大事故次数

7. 相关记录

《信息安全风险评估报告》

《信息安全事件统计表》